

Purple Team Outline

Week 04: Lateral Movement & Internal Network Attacks

Objective: To simulate the post-exploitation phase where an attacker moves through the internal environment.

Task 01: SMB Protocol Abuse & Enumeration

- **Description:** Exploit weak internal configurations to gain further access.
- **Technical Requirements:**
 - Perform Internal Enumeration of Shared Resources (Admin shares, IPC\$, etc.) after compromising the SMB protocol.
 - Analyze SMB traffic in Wireshark to identify cleartext authentication or sensitive file transfers.
- **Learning Goal:** Understand why SMB is a primary target for internal movement and how it can be secured.
- **What to Document :**
 - What is the difference between **port 139** and **port 445** in the context of SMB communication? Explain why modern systems prefer using **port 445** for file sharing within a LAN instead of port 139.
 - Describe a well-known historical attack related to **SMBv1** (e.g., ransomware outbreaks or major exploits). Explain how the attack worked at a high level and why SMBv1 was vulnerable.
 - Is this type of attack still a threat today? Justify your answer by discussing:
 - Modern security improvements
 - Remaining risks in poorly configured systems
 - Use **Nmap** to identify the SMB service and determine its version running on the victim machine → Attach a screenshot of the scan results showing the SMB version.

- Use **Nmap NSE scripts** to enumerate available SMB shares on the target system & Identify accessible shares (e.g., **IPC\$**, **ADMIN\$**, or others) → Attach a screenshot of the discovered shares.
- Use an SMB client tool to connect to the discovered shares, list and explore the files available within accessible shares → Identify any sensitive or useful information (e.g., configuration files, credentials).
- Run **Wireshark** in the background during SMB interactions, capture and analyze SMB traffic, Look for: Authentication attempts, File transfers & Any sensitive information in transit
- Design a realistic lab scenario where:
 - Initial access is gained on one machine (e.g., via SMB).
 - Credentials or sensitive data are discovered on that system.
 - The discovered credentials are then used to access another machine within the same network.
- Clearly explain:
 - How the credentials were obtained (conceptually)
 - How they were reused
 - How access to the second system was achieved

Task 02: Practical Lateral Movement

- **Description:** Expand the “attack surface” by moving laterally from one compromised service to another within the same network.
- **Technical Requirements:**
 - Practice moving laterally by utilizing credentials or sensitive information discovered on one service to access another system on the same network.
 - Observe and document artifacts left behind during credential reuse, service compromise, or Pass-the-Hash style techniques (conceptually).
- **Learning Goal:**
 - Understand and practice lateral movement techniques used by attackers to traverse an internal network.
 - Learn to identify potential weaknesses and residual evidence left by internal movement.

- **What to Document :**

- Why is **lateral movement** necessary when performing a penetration test on a network? When pentesting systems within the **same network**, is it necessary to perform **pivoting** to compromise other systems? If not, explain why with a valid reason.
- A pentester can escalate privileges in two ways: **horizontal** or **vertical**. Do you think these concepts also apply to **lateral movement**? Explain your reasoning.
- Use the credentials or information obtained to access another machine on the same network & specify **which service** you used to gain access (e.g., SSH, SMB, RDP, etc.) → Attach a screenshot showing successful access to the second system.
- Enumerate accessible files, directories, or shares on the second machine (conceptually or with screenshots if applicable), Note any sensitive data discovered.
- Explain how the initial SMB enumeration enabled lateral movement.